**ФАКУЛЬТЕТ ІНФОРМАЦІЙНИХ ТЕХНОЛОГІЙ**
**КИЇВСЬКОГО НАЦІОНАЛЬНОГО УНІВЕРСИТЕТУ**
**ІМЕНІ ТАРАСА ШЕВЧЕНКА**

**Кафедра інформаційних систем та технологій**

**І.І. БОРИСЕНКО**
**М.В. ГЛАДКА**

# КІБЕРНЕТИЧНА БЕЗПЕКА ПІДПРИЄМСТВА

**рекомендації до виконання лабораторних робіт**
**для здобувачів освітнього ступеня «бакалавр» спеціальності**

**126 «Інформаційні системи та технології»**

**освітня програма «Програмні технології інтернет речей»**

**Київ 2025**

**Рецензенти:**

*д.т.н., професор, професор кафедри кібербезпеки та захисту інформації Толюпа Сергій Васильович;*

*к.т.н., доц., професор кафедри інженерії програмного забезпечення ФКНТ, ДНП ДУ «Київський авіаційний інститут» Гізун Андрій Іванович*

Рекомендовано до публікації кафедрою інформаційних систем та технологій, протокол №09_24/25 від 06 лютого 2025 року

**І.І. Борисенко, М.В. Гладка**

**Кібернетична безпека підприємства** [Електронний ресурс]: рекомендації до лабораторних робіт для здобувачів освітнього ступеня «бакалавр» спеціальності 126 «Інформаційні системи та технології» освітня програма «Програмні технології інтернет речей» уклад.: І.І. Борисенко, М.В. Гладка– К.: КНУ імені Тараса Шевченка, 2025.– 33 с.

Лабораторний практикум з дисципліни «**Кібернетична безпека підприємства**».

Рекомендації містять 4 лабораторних роботи призначених для виконання в комп'ютерному класі. Метою лабораторних робіт є засвоєння і поглиблення теоретичних знань, набуття практичних навиків та вмінь щодо інформаційної безпеки.

Публікується в авторській редакції.

Електронна версія цього видання опублікована на сайті кафедри інформаційних систем та технологій факультету інформаційних технологій Київського національного університету імені Тараса Шевченка.

© **І.І. Борисенко, М.В. Гладка** 2025

## Зміст

ВСТУП ..... 4
ЛАБОРАТОРНА РОБОТА №1 Дослідження структури системи управління кібернетичною безпекою підприємства. ..... 5
ЛАБОРАТОРНА РОБОТА №2 Аналіз процесу управління ризиками кібернетичної безпеки підприємства ..... 14
ЛАБОРАТОРНА РОБОТА №3 Аналіз кількісних та якісними методів ідентифікації активів підприємства ..... 19
ЛАБОРАТОРНА РОБОТА №4 Аналіз видів, критичності та наслідків відмов (FMEA) ..... 22
Рекомендована література ..... 30
ДОДАТОК А. Приклад тем для дослідження ..... 32

# ВСТУП

Сучасний світ тісно пов’язаний з застосуванням інформаційних технологій та інформаційних систем. Кібернетичний простір наповнений інформацією, яка постійно змінюється та впливає на якісь та економічні показники підприємств . Кіберзлочинці намагаються порушити основні властивості інформації, що може призвести до зростання вразливостей інформаційних систем та стати серйозною загрозою для організацій. Виходячи з вище сказаного можна зробити висновок, що організація кібернетичної безпеки підприємства найбільш ефективний та економічно обґрунтований варіант запобігання безпосередньо наслідкам від реалізації загроз.

Організація та управління кібернетичною безпекою підприємства тісно пов’язане з процесом забезпечення безпеки інформаційних ресурсів організації, яка заснована на стандартах України, міжнародних стандартах ISO / IEC 27001: 2022. В кожній окремій організації є власні вимоги та потреби , які пов’язані зі сферою діяльності, правовими вимогами, які вже висунуто в нормативних документах України.

Це видання містить 4 лабораторних роботи, основними темами яких є: Дослідження структури системи управління кібернетичною безпекою підприємства, Дослідження основних напрямків розвитку менеджменту у сфері кібернетичної безпеки підприємства, Аналіз процесу управління ризиками кібернетичної безпеки підприємства, Аналіз видів і наслідків відмов, та аналіз видів, наслідків та критичності відмов (FMEA), Аналіз кількісних та якісними методів ідентифікації активів підприємства, Аудит кібернетичної безпеки підприємства.

**Звіт з кожної роботи повинен містити:** титульний аркуш із зазначенням найменування лабораторні роботи; мету роботи; постановка задачі згідно з завдання; хід і результати дослідження в графічній формі; відповіді на питання для самоперевірки; аналіз результатів та висновки.

## ЛАБОРАТОРНА РОБОТА №1
## Дослідження структури системи управління інформаційною безпекою підприємства.

**Мета:** проаналізувати структури системи управління кібернетичною безпекою підприємства та основні стандарти в цій галузі.

**Завдання.**

1. Ознайомитись з поняттям та основними положеннями інформаційної безпеки. Дослідити основні цілі та завдання інформаційної безпеки
2. Проаналізувати Стандарт ISO / IEC 27001: 2022.
3. Дослідити застосування Стандарт ISO / IEC 27001: 2022 для організації кібернетичної безпеки на підприємстві.
4. У будь-якому графічному редакторі зобразити модель системи інформаційної безпеки підприємства у відповідності до індивідуального варіанту. Перелік варіантів Додаток А. Варіанти обираються здобувачем у відповідності до власних вподобань, але з обов'язковим погодженням з викладачем.
5. Виконати представлення кібернетичної безпеки підприємства на базі міжнародних стандартів ISO/IEC 27001.
6. Дослідіть інші стандарти в галузі інформаційної безпеки. Заповніть таблицю стандартів, які можна використати для безпеки вашого підприємства (за індивідуальним варіантом) за представленим нижче переліком, або використайте інші, необхідні для захисту вашого підприємства стандарти:

Таблиця 1.1. Стандарти та їх опис

| Стандарт | Короткий зміст | Застосування (область застосування саме на обраному підприємстві) |
|---|---|---|
| | | |

- ISO/IEC IS 27001:2013 – Information security management systems – Requirements Системи менеджменту інформаційної безпеки – Вимоги.
- ISO/IEC IS 27006:2015 – Requirements for bodies providing audit and certification of information security management systems (published). Вимоги до органів, що здійснюють аудит і сертифікацію систем менеджменту інформаційної безпеки.
- ISO/IEC IS 27002:2013 – Code of practice for information security controls (published). Практичні правила для заходів з інформаційної безпеки.
- ISO/IEC 27003:2012 – Information security management systems implementation guidance (published). Настанова з реалізації систем менеджменту інформаційної безпеки.
- ISO/IEC 27004:2011 – Information security management measurements (published). Вимірювання менеджменту інформаційної безпеки.

- ISO/IEC IS 27005:2011 – Information security risk management (published). Керування ризиками інформаційної безпеки.
- ISO/IEC 27007:2014 – Guidelines for information security management systems auditing (published). Настанова з аудиту систем менеджменту інформаційної безпеки.
- ISO/IEC TR 27008:2011 – Guidance for auditors on ISMS controls (published). Настанова для аудиторів заходів ISMS.
- ISO/IEC 27013:2017 – Guidance on the integrated implementation of 20000-1 and 27001 (published). Настанова з інтегрованої реалізації стандартів ISO/IEC 20000-1 і ISO/IEC 27001.
- ISO/IEC 27014:2013 – Information security governance framework (published). Основні положення управління інформаційною безпекою.
- ISO/IEC 27010:2015 – Information security management guidelines for inter-sector communications (published). Настанови з менеджменту інформаційної безпеки для міжгалузевих зв'язків.
- ITU X.1051|ISO/IEC 27011: 2018 – Information security management guidelines for telecommunications organizations based on ISO/IEC 27002. Настанова з менеджменту інформаційної безпеки для телекомунікаційних організацій на основі ISO/IEC 27002.
- ISO/IEC 27015:2012 – Information security management guidelines for financial and insurance services (published). Настановчі вказівки з менеджменту інформаційної безпеки для фінансових послуг і послуг страхування.
- ISO/IEC 27031:2011 – Guidelines for ICT readiness for business continuity (published). Настановчі вказівки щодо готовності ІКТ для підтримки неперервності бізнесу.
- ISO/IEC 27033 – Network security (all parts). Безпека мереж (всі частини). ISO/IEC 27034 – Application security (all parts). Безпека додатків (всі частини).
- ISO/IEC 27035:2018 – Information security incident management. Менеджмент інцидентів інформаційної безпеки.
- ISO/IEC 27037:2017 – Guidelines for identification, collection and/or acquisition and preservation of digital evidence). Настановчі вказівки для ідентифікації, збору і/або придбання і зберігання цифрових доказів.

**Необхідні ресурси**

ПК або мобільний пристрій з доступом до Інтернету.

**Довідкова інформація**

Поняття «інформаційна безпека» з'явилось завдяки розвитку засобів інформаційних комунікацій серед суспільства. У сучасному світі стрімкий розвиток інформаційних технологій не є новиною. Збільшується кількість інформаційних систем, програмних забезпечень, які допомагають персоналу підприємства управляти інформаційними потоками. Відповідно до цього збільшується кількість цінної інформації. Тому питання про її захист стоїть

досить гостро. Необхідно зазначити, що у науковій літературі відсутній єдиний погляд на зміст поняття інформаційна безпека»[1].

Під поняттям «інформаційна безпека» розуміють стан (рівень) захищеності інформаційних ресурсів – інформаційних об'єктів та інформаційних систем – від негативних впливів (як випадкових, так і здійснюваних навмисно), які можуть завдати шкоди самій інформації та засобам її передачі та обробки, а, отже, негативно відбитися на власниках інформаційних ресурсів, державі, суспільстві та інших учасниках процесів інформаційного обміну. Більшість сучасних інформаційних ресурсів, а також інформаційних систем практично не можуть розглядатися у відриві від комплексу елементів (факторів), пов'язаних із забезпеченням інформаційної безпеки: загроз для інформаційних ресурсів, різних засобів і заходів захисту, бар'єрів для проникнення, а також вразливостей в системах захисту інформації [2]. Таким чином, під інформаційною безпекою в більш загальному вигляді можна визначити як сукупність засобів, методів і процесів (процедур), які забезпечують захист інформаційних активів і гарантують збереження ефективності та практичної корисності як технічної інфраструктури інформаційних систем, так і відомостей, які в таких системах зберігаються і обробляються. Мета інформаційної безпеки полягає в тому, щоб зберегти цілісність, повноту та точність інформації, зменшити ризик несанкціонованих змін в інформаційних системах. Для того, щоб забезпечити підприємству розвиток та конкурентоспроможність, необхідно створити систему управління інформаційною безпекою [3].

Одним з ключових чинників успішності системи управління інформаційною безпекою підприємства – це побудова її на базі міжнародних стандартів ISO/IEC 27001.

Міжнародний стандарт ISO 27001 надає інструмент для розробки, впровадження, супроводу, моніторингу, підтримки та вдосконалення добре документованої системи управління інформаційною безпекою в контексті розгляду бізнес ризиків [1].

Для розробки стандартів у галузі безпеки інформаційних технологій засновано підкомітет SC 27 "Security techniques" (Методи забезпечення безпеки) у рамках об'єднаного технічного комітету ISO/IEC JTC 1 "Information technology" (Інформаційні технології). Широкий спектр питань інформаційної безпеки, розглянутих фахівцями, залученими до діяльності SC 27, розподілений між п'ятьма робочими групами, що становлять весь підкомітет. За кожною групою закріплено відповідний напрям[4].

Перша робоча група (РГ 1) "Information Security Management Systems" (Системи менеджменту ІБ) займається розробкою стандартів і настановчих вказівок щодо побудови систем менеджменту інформаційної безпеки (ISMS).

***Основними цілями інформаційної безпеки є:***

• конфіденційність інформації, тобто необхідність введення обмежень доступу до даної інформації для певного кола осіб;

• неможливість несанкціонованого доступу до інформації, тобто ознайомлення з конфіденційною інформацією сторонніх осіб;

• цілісність інформації та пов'язаних з нею процесів (створення, введення, обробка і виведення), яка полягає в її існуванні в неспотвореному вигляді (незміненому по відношенню до деякому фіксованому її станом);

• доступність інформації, тобто здатність забезпечувати своєчасний і безперешкодний доступ осіб до їх інформації;

• мінімізація ризиків інформаційної безпеки шляхом виконання компенсаційних заходів;

• облік усіх процесів, пов'язаних з ризиками [5].

***Досягнення заданих цілей здійснюється в ході вирішення наступних завдань:***

• введення в систему термінів інформаційної безпеки;

• класифікації інформаційних ресурсів підприємства;

• визначення власників процесів, відповідальних за інформаційну безпеку;

• розробки спектра ризиків інформаційної безпеки та проведення їх експертних оцінок;

• визначення групи доступу до інформаційних ресурсів;

• розробки системи управління ризиками інформаційної безпеки (методи та їх оцінка);

• складання переліків адміністративних і технічних заходів для мінімізації та компенсації ризиків;

• здійснення заходів інформаційної безпеки та періодичного контролю за станом ризиків;

• забезпечення фізичної безпеки та безпеки персоналу;

• розробки вимог до інформаційної системи з погляду інформаційної безпеки;

• контролінгу інформаційної безпеки на підприємстві [5].

***Виділяються чотири стадії реалізації системи управління інформаційною безпекою:***

1) формування політики в галузі ризиків;

2) аналіз бізнес-процесів;

3) аналіз ризиків;

4) формування цільової концепції.

Формування політики в галузі ризиків передбачає визначення принципів управління ними для всього підприємства в цілому. Ці принципи базуються на цілях підприємства, його стратегії, також на вимогах, пропонованих законом і стандартами в галузі інформаційної безпеки. Чинником ефективності системи управління інформаційною безпекою є її побудова на базі міжнародних стандартів ISO / IEC 17799: 2005 та ISO / IEC 27001: 2022 [1].

Стандарт ISO / IEC 17799: 2005 визначає принципи та є керівництвом з розробки, впровадження, супроводу та поліпшення системи управління інформаційною безпекою, а також описує механізми визначення цілей контролю і його цінності у таких областях:

• політика безпеки (встановлення принципів управління і засобів забезпечення захисту інформації);

• управління безперервністю бізнес-процесів (запобігання втручання в ділові операції і захист процесів обробки інформації від наслідків серйозних несправностей або катастроф);

• дотримання правових норм (виняток порушень кримінального та цивільного права, установлених законом зобов'язань, регулятивних або контрактних зобов'язань, а також вимог щодо безпеки);

• організація активів і ресурсів (управління захистом інформації всередині організації);

• фізична безпека і безпека навколишнього середовища (запобігання несанкціонованого доступу, пошкодження і проникнення в службові приміщення або втручання в ділову інформацію);

• класифікація і управління активами (виявлення та захист інформаційних активів);

• захист персоналу (зниження ризиків, пов'язаних з помилкою оператора, крадіжкою, шахрайством або зловживанням обладнанням);

• управління доступом (контроль доступу до інформації);

• управління засобами зв'язку і експлуатацією устаткування (коректне і безпечне функціонування засобів обробки інформації);

• розробка та обслуговування систем (впровадження засобів захисту в інформаційні системи) [6].

Стандарт ISO / IEC 27001: 2022 встановлює вимоги до системи управління інформаційною безпекою підприємства, є керівництвом за визначенням, мінімізації та управління небезпеками і погрозами, яким може піддаватися інформація, і розроблений з метою забезпечення допомоги у виборі ефективних і адекватних засобів для його захисту.

***Застосування стандарту ISO / IEC 27001: 2022 на підприємстві дозволяє:***

• встановити вимоги і цілі в області інформаційної безпеки;

• гарантувати впевненість у тому, що управління ризиками в області інформаційної безпеки є ефективним, а також те, що діяльність підприємства відповідає законодавству та іншим нормативним документам;

• реалізувати процес контролю за впровадженням системи управління інформаційною безпекою;

• ідентифікувати і відстежувати існуючі процеси управління інформаційною безпекою;

• керівництву підприємства визначити стан процесів управління захистом інформації;

• внутрішнім і зовнішнім аудиторіям встановити рівень відповідності політики безпеки регламентам;

• забезпечити партнерів і постачальників відповідною інформацією про стандарти, процедурах та політиці підприємства.

Система управління інформаційною безпекою (Information Security Management System) є частиною загальної системи управління, що базується на аналізі ризиків і призначеної для проектування, реалізації, контролю, супроводу

та вдосконалення заходів в області інформаційної безпеки (кібербезпеки). Систему складають організаційні структури, політика, дії з планування, обов'язки, процедури, процеси і ресурси [7].

***Модель системи інформаційної безпеки підприємства*** - це сукупність зовнішніх і внутрішніх факторів, їх вплив на стан інформаційної безпеки підприємства і забезпечення схоронності ресурсів. Модель системи інформаційної безпеки підприємства містить в собі напрямки впливу між наступними факторами:

• загрозами інформаційній безпеці, які характеризуються ймовірністю виникнення та реалізації;

• вразливістю системи інформаційної безпеки, що впливає на ймовірність реалізації загрози;

• ризиками, що відображають передбачуваний збиток в результаті реалізації загрози інформаційній безпеці [1].

Інформація та матеріальні ресурси, які необхідно захищати, називаються ***об'єктами захисту***.

Загрози, з якими може зіткнутися підприємство, класифікуються за природою їх виникнення, тобто загрози випадкового або навмисного характеру, і по тому, як вони ставляться до захищається, тобто зовнішні і внутрішні загрози.

***Джерелами зовнішніх загроз є:***

• діяльність конкурентів з перехоплення важливої інформації;

• навмисні дії з руйнування, знищення або модифікації інформації;

• ненавмисні дії співробітників сторонніх організацій, які потягли за собою відмову в роботі елементів системи;

• стихійні лиха та катастрофи, аварії, екстремальні ситуації.

***До джерел внутрішніх загроз відносяться:***

• відсутність координації діяльності підрозділів підприємства у сфері захисту інформації;

• навмисні дії персоналу по знищенню або модифікації інформації;

• ненавмисні помилки персоналу, відмови технічних засобів і збої в інформаційних системах;

• порушення встановлених регламентів збору, накопичення, зберігання, обробки, перетворення, відображення та передачі інформації [7].

***Порушення можуть бути декількох видів.***

***Організаційно-правові порушення*** - порушення, пов'язані з відсутністю єдиної узгодженої політики підприємства у сфері захисту інформації, невиконанням вимог нормативних документів, режимом доступу, зберігання та знищення інформації.

***Організаційні види порушень*** включають несанкціоноване отримання доступу до баз і масивам даних, несанкціонований доступ до активного мережевого обладнання, серверів, некоректне вбудовування засобів захисту і помилки в управлінні ними, порушення в адресності розсилки інформації при веденні інформаційного обміну.

Під фізичними видами порушень розуміють пошкодження апаратних засобів автоматизованих систем, ліній зв'язку і комунікаційного устаткування, крадіжки або несанкціоноване ознайомлення зі змістом носіїв інформації, їх розкрадання [8].

До радіоелектронних видів порушень відносяться впровадження електронних пристроїв перехоплення інформації, отримання інформації шляхом перехоплення і дешифрування інформаційних потоків, фотографування моніторів, нав'язування неправдивої інформації в локальних обчислювальних мережах, передачі даних і лініях зв'язку [9].

Для протидії загрозам і припинення порушень на підприємствах організовується процес управління ризиками, який є основою системи інформаційної безпеки підприємства.

***Побудова ефективної системи інформаційної безпеки*** - це комплексний процес, спрямований на мінімізацію зовнішніх і внутрішніх загроз при обліку обмежень на ресурси і час.

З погляду процесного підходу систему інформаційної безпеки підприємства можна представити як процес управління ризиками, який включає в себе наступні складові.

***1. Опис бізнес-процесів.*** Виконується коригування та аналіз бізнеспроцесів. За критеріями, які визначаються в ході формування політики в

галузі ризиків, здійснюється ідентифікація бізнес-процесів.

***2. Збір ризиків.*** Проводиться для виявлення ступеня схильності підприємства загрозам, які можуть завдати істотної шкоди. Для цього здійснюється аналіз його бізнеспроцесів і опитування експертів предметної області. Результатом (виходом) даного процесу вважається класифікаційний перелік всіх потенційних ризиків.

До стандартних ризиків інформаційної безпеки відносяться:

• вилучення конфіденційної інформації з локальних місць;

• навмисне зміна інформації з метою знищення;

• копіювання важливих документів і передача конкуренту;

• незаконне проникнення в корпоративну мережу;

• знищення з технічних причин.

***3. Оцінка ризиків.*** Визначаються характеристики ризиків і ресурси інформаційної системи (Рис. 1.1.). Основним результатом (виходом) даного процесу є перелік всіх потенційних ризиків з їх кількісними та якісними оцінками збитку і можливості реалізації, а додатковим - перелік ризиків, які не будуть відслідковуватися на підприємстві.

Процес оцінки ризиків складається з наступних кроків:

• опис об'єкта і заходів захисту;

• ідентифікація ресурсу і визначення його кількісних показників;

• аналіз загроз інформаційної безпеки;

• оцінка вразливостей;

• оцінка існуючих і передбачуваних засобів забезпечення інформаційної безпеки.

***4. Планування заходів.*** Метою планування заходів щодо мінімізації ризиків є визначення термінів та переліку робіт по виключенню або мінімізації збитку у разі мінімізації ризику.

Виділяються наступні види заходів з інформаційної безпеки:

• організаційні;
• правові;
• організаційно-технічні;
• програмні;
• інженерно-технічні.

***5. Реалізація заходів.*** Під реалізацією заходів щодо мінімізації ризиків розуміють виконання запланованих робіт, контроль якості отриманих результатів та термінів. Результатом даного процесу є виконані роботи з мінімізації ризиків і час їх проведення.

***6. Оцінка ефективності.*** Оцінка ефективності системи управління інформаційною безпекою - це системний процес отримання та оцінки об'єктивних даних про поточний стан системи, дії і події, що відбуваються в ній, встановлює рівень їх відповідності певним критеріям [10].

Цілями процесу є:

• оцінка поточного рівня ефективності системи;
• локалізація "вузьких" місць у системі;
• оцінка відповідності системи підприємства існуючим стандартам в галузі інформаційної безпеки;
• вироблення рекомендацій і регламентів по забезпеченню безпеки об'єктів захисту [11].

Результати процесу можуть використовуватися в цілях аудиту для підготовки підприємства до сертифікації за стандартом ISO / IEC 27001: 2022.

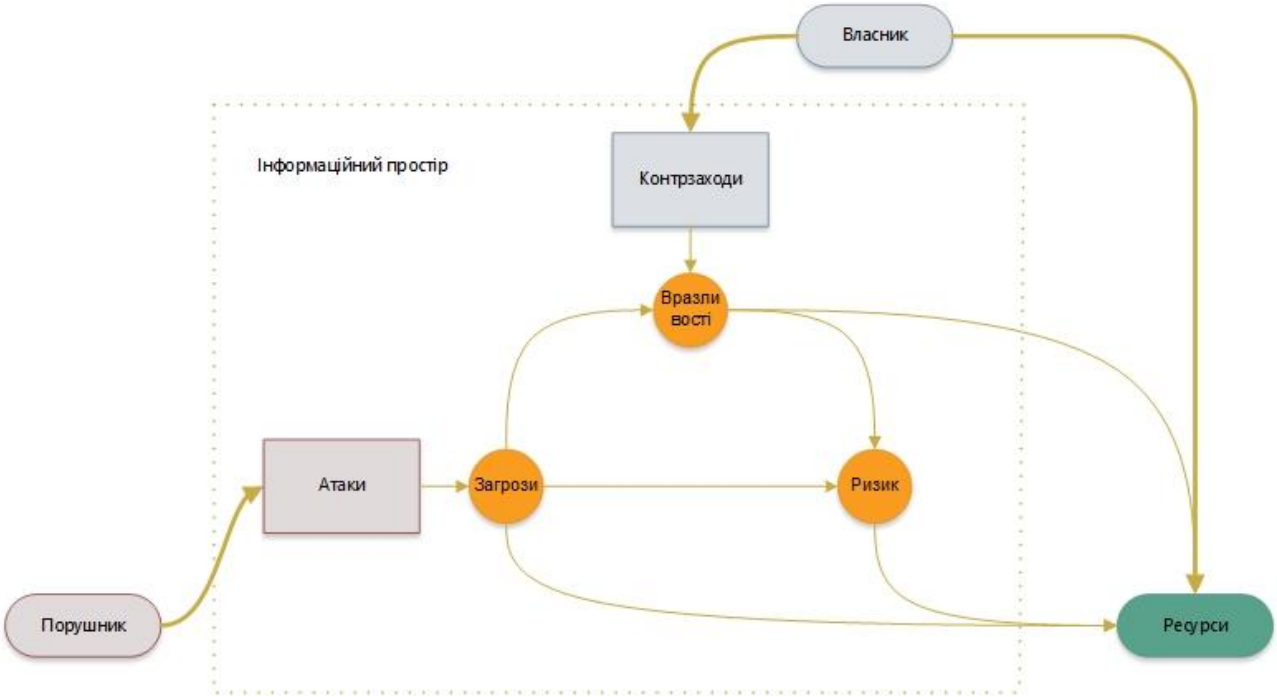



Рисунок 1.1 Структура системи інорфмаційної безпеки

## Питання для самоперевірки:

1. Яким чином визначаються терміни інформаційної безпеки? Назвіть приклади.
2. Розкрийте поняття "заходи інформаційної безпеки".
3. Яким чином може здійснюватись забезпечення фізичної безпеки та безпеки персоналу на підприємстві чи в організації?
4. Яким чином відбувається аналіз ризиків?
5. Розкрийте поняття "об’єкти захисту", що до них відноситься, наведіть приклади.
6. Що таке "загрози"? Їх види та джерела. Наведіть приклади.
7. Види заходів інформаційної безпеки. Докладно розкрийте кожен з них.
8. Яким чином та з якою метою відбувається оцінка ефективності системи управління кібербезпекою? Назвіть ключові чинники успішності системи управління інформаційною безпекою підприємства?
9. Які основні вимоги до стандартів міжнародних стандартів ISO/IEC 27001? З яких елементів складається стандарт?
10. Які основні стандарти серії ISO 27К Ви знаєте?

## ЛАБОРАТОРНА РОБОТА №2

**Аналіз процесу управління ризиками кібернетичної безпеки підприємства**

**Мета:** За допомогою CCTA Risk Analysis and Managment Method навчитись процесу управління ризиками інформаційної безпеки підприємства.

**Завдання.**

1. Дослідити поняття управління ризиками.
2. Дослідити процес управління ризиками на підприємстві.
3. Дослідити методологію CRAMM.
4. Перерахуйте основні аспекти управлінської роботи щодо забезпечення інформаційної безпеки на рівні підприємства за індивідуальним варіантом (у відповідності до лабораторної роботи 1).
5. Перерахуйте основні аспекти управлінської роботи щодо забезпечення інформаційної безпеки на рівні підприємства. Заповніть табл. 3.1. усіма можливими методиками, які можуть бути застосовані для безпеки вашого підприємства (за індивідуальним варіантом). Розширте перелік тими методиками, які найкраще підходять для діяльності вашого напрямку (індивідуального варіанту).

| Методика | Опис методики і її застосування на підприємтві |
|---|---|
| | |
| | |
| | |
| | |
| | |

6. Заповніть табл. 3.2. Переваги та недоліки методик з управління ризиками ІБ

| Методика | Переваги | Недоліки |
|---|---|---|
| **CRAMM** | | |
| **COBIT 5 for Risk** | | |
| **FRAP** | | |
| **NIST 800-30** | | |
| **Octave** | | |

**Необхідні ресурси**

ПК або мобільний пристрій з доступом до Інтернету

**Довідкова інформація**

Забезпечення власної інформаційної безпеки на підприємствах, як правило, є невід'ємною частиною загальної системи управління, необхідної для досягнення статутних цілей та завдань. Значимість систематичної цілеспрямованої діяльності щодо забезпечення інформаційної безпеки стає тим

більш високою, чим вище ступінь автоматизації бізнес-процесів підприємства, і чим більше "інтелектуальна складова" в його кінцевому продукті, тобто чим більшою мірою успішність діяльності залежить від наявності та збереження певної інформації (технологій, ноу-хау, комерційних баз даних, маркетингової інформації, результатів наукових досліджень тощо), забезпечення її конфіденційності та доступності для власників і користувачів. Роль інформації в діяльності підприємств зростає в міру лібералізації світових ринків, коли матеріальні активи меншою мірою є джерелами конкурентних переваг в силу значного зменшення торгівельних бар'єрів. Нематеріальні активи, існуючі зазвичай у вигляді інформації, в цих умовах починають грати роль однієї з провідних засад для підвищення конкурентоспроможності та розвитку бізнесу [1].

Забезпечення інформаційної безпеки також, як правило, має велике значення не тільки для стратегічного розвитку підприємства і створення основного продукту, але і для окремих (іноді допоміжних) напрямків діяльності та бізнес-процесів, таких як комерційні переговори і умови контрактів, цінова політика, тощо. Крім того, значимість забезпечення інформаційної безпеки в деяких випадках може визначатися наявністю в загальній системі інформаційних потоків підприємства відомостей, що становлять не тільки комерційну, а й державну таємницю, а також інші види конфіденційної інформації (відомості, що становлять банківську таємницю, лікарську таємницю, інтелектуальну власність компаній-партнерів тощо) [12].

Так само як і на державному рівні, управління інформаційною безпекою на рівні підприємств націлене на нейтралізацію різних видів загроз:

- зовнішніх, таких як неправомірні дії державних органів (у тому числі і закордонних), протиправна діяльність злочинців і злочинних угруповань, незаконні дії компаній-конкурентів та інших господарюючих суб'єктів, недобросовісні дії компаній-партнерів, невідповідність чинної нормативно-правової бази фактичному розвитку технологій і суспільних відносин, збої і порушення в роботі глобальних інформаційних та телекомунікаційних систем та інформаційних систем компаній-партнерів (контрагентів) та ін.;
- внутрішніх, таких як помилки і халатність персоналу підприємства, а також навмисно допускаються порушення, збої і порушення в роботі власних інформаційних систем [13].

Таким чином, управління інформаційною безпекою на кожному окремому підприємстві має здійснюватися в контексті його загальної господарської діяльності: з урахуванням характеру діяльності компанії (технології виробництва, специфіки ринків збуту тощо), а також як фактично складається ситуація у ринковій конкурентній боротьбі, державній політиці, розвитку правової та правоохоронної системи, рівня розвитку окремих використовуваних інформаційних і телекомунікаційних технологій та інших факторів, що формують загальні умови поточної діяльності [1].

Розглянемо методику CRAMM (CCTA Risk Analysis and Managment Method), яку розробило Агентство з комп’ютерів і телекомунікацій

Великобританії (Central Computer and Telecommunications Agency) за поданням Британського уряду і яка прийнята за державний стандарт. Цю методику використовують, починаючи з 1985 року, державні та комерційні організації Великобританії. За цей час CRAMM набула популярності у всьому світі. Фірма Insight Consulting Limited займається розробленням і супроводом однойменного програмного продукту, що реалізує метод CRAMM.

В основу методики CRAMM покладено комплексний підхід до оцінки ризиків, що поєднує кількісні та якісні методи аналізу. Методика є універсальною і придатна як для великих, так і для малих організацій, як державного, так і комерційного сектору. Версії програмного забезпечення CRAMM, орієнтовані на різні типи організацій, відрізняються своїми базами знань (profiles). Для комерційних організацій є комерційний профіль (Commercial Profile), для державних організацій – державний профіль (Government profile). Державний варіант профілю також дає змогу проводити аудит на відповідність вимогам американського стандарту ITSEC ("Помаранчева книга").

Метою розробки методики було створення формалізованої процедури, що дозволяє:

• переконатися, що вимоги, пов'язані з безпекою, повністю проаналізовані та задокументовані;

• уникнути витрат на зайві заходи безпеки, можливі при суб'єктивній оцінці ризиків;

• надавати допомогу у плануванні та здійсненні захисту на всіх стадіях життєвого циклу інформаційних систем:

• забезпечити проведення робіт у стислі терміни;

• автоматизувати процес аналізу вимог безпеки;

• представити обгрунтування для заходів протидії;

• оцінювати ефективність контрзаходів, порівнювати різні їх варіанти;

• генерувати звіти.

Правильне використання методики CRAMM дає змогу економічно обґрунтувати витрати організації на забезпечення інформаційної безпеки та неперервності функціонування. Економічно обґрунтована стратегія управління ризиками ІБ дає змогу, в кінцевому підсумку, заощаджувати кошти, уникаючи невиправданих витрат.

Методика CRAMM припускає поділ всієї процедури на три послідовні етапи. Завданням першого етапу є відповідь на запитання: "Чи достатньо для захисту системи застосування засобів базового рівня, що реалізують традиційні функції ІБ, чи необхідне проведення детальнішого аналізу?" Надругому етапі здійснюється ідентифікація ризиків і оцінюється їх величина. На третьому етапі вирішується завдання про вибір адекватних контрзаходів. Методика CRAMM для кожного етапу визначає набір вихідних даних, послідовність заходів, анкети для проведення інтерв'ю, списки перевірки і набір звітних документів.

Основною методикою, яку потрібно проаналізувати є методика CRAMM (CCTA Risk Analysis and Managment Method), яку розробило Агентство з

комп’ютерів і телекомунікацій Великобританії (Central Computer and Telecommunications Agency) за поданням Британського уряду і яка прийнята за державний стандарт. Цю методику використовують, починаючи з 1985 року, державні та комерційні організації Великобританії. За цей час CRAMM набула популярності у всьому світі. Фірма Insight Consulting Limited займається розробленням і супроводом однойменного програмного продукту, що реалізує метод CRAMM [14].

В основу методики CRAMM покладено комплексний підхід до оцінки ризиків, що поєднує кількісні та якісні методи аналізу. Методика є універсальною і придатна як для великих, так і для малих організацій, як державного, так і комерційного сектору. Версії програмного забезпечення CRAMM, орієнтовані на різні типи організацій, відрізняються своїми базами знань (profiles). Для комерційних організацій є комерційний профіль (Commercial Profile), для державних організацій – державний профіль (Government profile). Державний варіант профілю також дає змогу проводити аудит на відповідність вимогам американського стандарту ITSEC (“Помаранчева книга”).

Правильне використання методики CRAMM дає змогу економічно обґрунтувати витрати організації на забезпечення інформаційної безпеки та неперервності функціонування. Економічно обґрунтована стратегія управління ризиками ІБ дає змогу, в кінцевому підсумку, заощаджувати кошти, уникаючи невиправданих витрат.

Методика CRAMM припускає поділ всієї процедури на три послідовні етапи. Завданням першого етапу є відповідь на запитання: “Чи достатньо для захисту системи застосування засобів базового рівня, що реалізують традиційні функції ІБ, чи необхідне проведення детальнішого аналізу?” Надругому етапі здійснюється ідентифікація ризиків і оцінюється їх величина. На третьому етапі вирішується завдання про вибір адекватних контрзаходів. Методика CRAMM для кожного етапу визначає набір вихідних даних, послідовність заходів, анкети для проведення інтерв’ю, списки перевірки і набір звітних документів [15].

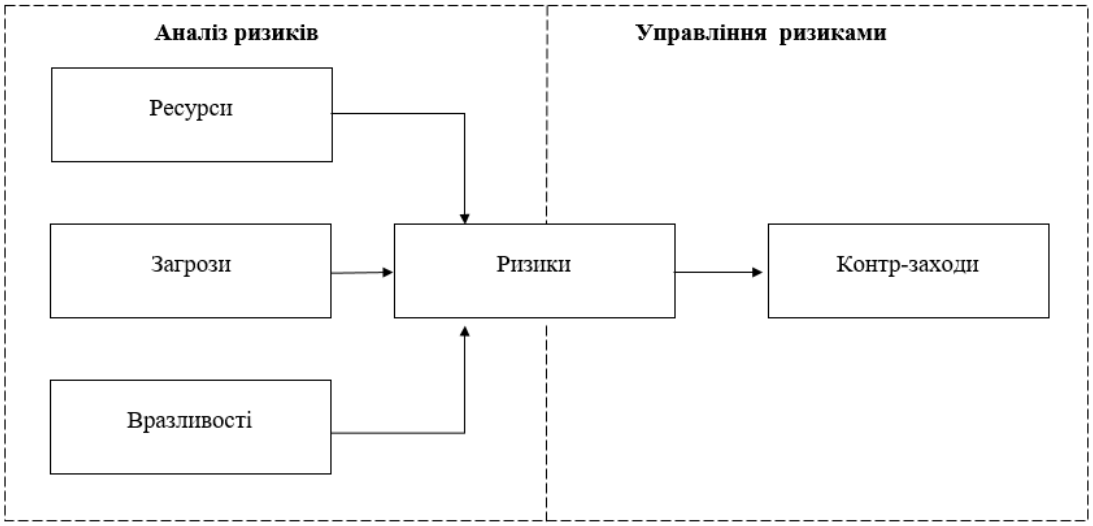



Рисунок 2.1. Методика CRAMM

## Питання для самоперевірки:

1. За допомогою яких механізмів здійснюється управління ризиками на підприємстві?
2. Що є управлінням інформаційною безпекою?
3. Основні положення методології CRAMM?
4. Що таке ресурси, загрози, вразливості?

## ЛАБОРАТОРНА РОБОТА №3

### Аналіз кількісних та якісних методів ідентифікації активів підприємства

**Мета:** ознайомитись з методикою оцінки ризиків OCTAVE та процесом аналізу ризиків FRAP.

**Завдання.**

1. Дослідити оцінку активів яка проводитися кількісними та якісними методами
2. Проаналізуйте методику оцінки ризиків OCTAVE.
3. Проаналізуйте груповий процес аналізу ризиків FRAP.
4. Виконайте класифікацію інформаційних активів, що знаходяться на вашому пристрої (мобільному телефоні, ноутбуці, домашньому ПК і т.д.).
5. Сформулюйте потенційні загрози інформації, визначіть методи та засоби їх уникнення.
6. Заповнити у вигляді таблиці відповідності "інформація-загрози-методи і засоби уникнення".

**Необхідні ресурси**

ПК або мобільний пристрій з доступом до Інтернету

**Довідкова інформація**

На цей час актуальним є питання забезпечення інформаційної безпеки. В свою чергу, для забезпечення інформаційної безпеки як окремих підприємств, так і держави в цілому важливим є питання оцінки ризиків, які виникають в процесі діяльності підприємств. Для оцінки ризиків інформаційної безпеки використовуються різні методики і стандарти управління інформаційними ризиками (УІР).

Аналіз ризиків інформаційної безпеки є методом виявлення вразливостей і загроз, оцінки можливого впливу, що дозволяє вибирати адекватні захисні заходи для тих систем і процесів, у яких вони необхідні.

Методики аналізу інформаційних ризиків дозволяють забезпечити ефективний і актуальний захист інформаційного простору підприємств і можливість вчасно реагувати на загрози інформаційній безпеці.

В цілому аналіз ризиків інформаційної безпеки передбачає облік активів і встановлення їхньої цінності для підприємства, класифікацію загроз і вразливостей, визначення ймовірності й впливу на діяльність підприємства цих потенційних загроз, а також оптимізацію витрат між збитками від впливу загроз і вартістю захисних заходів. Активи бувають матеріальні (мережеве обладнання, комп'ютери, програмне забезпечення, устаткування, матеріали) і нематеріальні (репутація, інформація, авторське право). Кількісно оцінити вартість нематеріальних активів набагато важче, ніж матеріальних [20].

Оцінка активів може проводитися кількісними та якісними методами.

Фактична вартість активів визначається на підставі вартості їх придбання, розробки й підтримки. Цінність активів визначається мірою їх необхідності для уповноважених і неуповноважених користувачів і власників.

Для забезпечення ефективності аналізу ризиків інформаційної безпеки на підприємстві має бути створена група управління інформаційними ризиками. До складу цієї групи входять керівники підрозділів, IT-працівники, розроблювачі додатків. Одним з перших завдань УІР-групи є визначення вартості активів підприємства і формування звіту з цих питань. Керівництво підприємства, проаналізувавши цей звіт, визначає обсяг УІР-проекту [21].

При визначенні вартості активів УІР-група повинна враховувати корисність і значення активів для підприємства; цінність активів для конкурентів, користувачів і власників цих активів; витрати на купівлю, розроблення, захист, заміну або ремонт активів при їх виході з ладу або втраті; наслідки у випадку компрометації активів тощо. Саме цінність активів визначає механізми безпеки та захисні заходи для їх захисту [1].

Після визначення цінності активів, відбувається ідентифікація загроз інформаційній безпеці підприємства, яка дозволяє встановити найбільш вразливі місця. Під час цієї ідентифікації встановлюються джерела загроз та їх наслідки, після чого проводиться аналіз можливих вразливостей від цих загроз і окреслюються шляхи протидії загрозам. Наприклад, джерелом загроз може бути хакер, який одержує доступ до конфіденційної інформації, за рахунок вразливості у вигляді великої кількості служб, запущених на сервері підприємства [6].

Після виявлення вразливостей і пов'язаних з ними загроз УІР-група повинна проаналізувати ризики потенційного збитку, а саме несанкціоноване розголошення конфіденційної інформації, зниження продуктивності роботи, пошкодження інформації або інформаційних систем та інші і доповісти про це керівництву підприємства для вживання адекватних заходів протидії. Проведемо порівняльний аналіз найбільш поширених на цей час методик оцінки ризиків інформаційної безпеки[22].

Методикою оцінки ризиків OCTAVE займається американський інститут Software Engineering Institute. Ця методологія передбачає здійснення процесу аналізу ризиків інформаційної безпеки лише працівниками підприємства без залучення зовнішніх консультантів, через те що такі працівники краще розуміють потреби підприємства і властиві йому ризики [23].

За цією методикою відбувається розробка профілю загроз, встановлення вразливостей інформаційній безпеці і розроблення стратегії забезпечення безпеки. Для кожного джерела загроз будується дерево варіантів, яке наочно показує вигляд загрози і шляхи її усунення. При оцінці ризиків інформаційній безпеці формується шкала за трьома позиціями: високий, середній та низький рівень ризику і встановлюється можливий фінансовий збиток. Основною перевагою даної методики є загальнодоступність і безкоштовність [24].

Для проведення якісної оцінки ризиків використовується груповий процес аналізу ризиків FRAP. Ця методика побудована таким чином , що будь-яка

людина з навиками організації групової роботи зможе успішно провести аналіз ризиків інформаційної безпеки. Згідно з цією методикою необхідно здійснити такі етапи, як мозкова атака для встановлення всіх загроз інформаційній безпеці підприємства; визначення ймовірності та вразливостей для кожної загрози за шкалою велика/середня/низька; формування звіту за результатами можливого впливу кожної із загроз. Перевагою цієї методики є швидкість і простота прийняття рішень. Також заслуговує на увагу метод аналізу й керування ризиками

Центрального агентства по комп'ютерах і телекомунікаціях (ССТА) Великобританії CRAMM. Цей метод поєднує кількісні та якісні методики оцінки ризиків. Метод є універсальним і може використовуватися великими і малими, державними і комерційними підприємствами.

Версії програмного забезпечення CRAMM орієнтовані на різні типи підприємств і відрізняються своїми базами знань. Для комерційних підприємств існує комерційний профіль, а для державних - урядовий профіль. Урядовий профіль дозволяє проводити аудит на відповідність вимогам стандарту ITSEC.

Метод CRAMM дозволяє економічно обґрунтувати витрати підприємства на забезпечення інформаційної безпеки і безперервність бізнесу.

Він розділений на три сегменти: ідентифікація й оцінка активів, аналіз загроз і вразливостей, вибір контрзаходів. Цей метод, незважаючи на значну універсальність та функціональність, має такі недоліки як необхідність спеціальної підготовки користувачів і значна вартість ліцензії.

Для оцінки ризиків інформаційної безпеки існують інші методики, які подібні до представлених. З проведеного аналізу можна навести такі рекомендації по вибору методик оцінки ризиків інформаційної безпеки: для невеликих підприємств доцільно використовувати методику OCTAVE, для середніх – FRAP, а для великих – CRAMM [5].

**Питання для самоперевірки:**

1. Дайте визначення "нематерільні активи підприємства", що відноситься до цієї категорії?
2. Дайте визначення активи підприємства? Наведіть приклади
3. Що таке активи підприємства? Які їх джерела та класифікація?
4. Які особливості методики оцінки ризиків OCTAVE?
5. Які особливості групового процесу аналізу ризиків FRAP?
6. Якими методами проводиться оцінка активів підприємства?
7. Розкрийте поняття "матерільні активи підприємства", що відноситься до цієї категорії?

## ЛАБОРАТОРНА РОБОТА №4
## Аналіз видів, критичності та наслідків відмов (FMEA)

**Мета:** проаналізувати метод FMEA, сферу застосування, процес виконання методу, переваги та недоліки методу FMEA.

**Завдання.**

1. Ознайомитись з методом FMEA – Failure Mode Effect Analysis
2. Ознайомитись зі сферою застосування FMEA.
3. Розробити функціональну схему досліджуваної системи.
4. Виконати FMECA досліджуваної системи за індивідуальним варіантом (у відповідності до лабораторної роботи 1)
5. Розробити функціональну схему досліджуваної системи:
   – аналіз структури та функцій системи;
   – поділ системи на частини та елементи на основі вплив відмов елементів на відмови системи та рівень деталізації.
6. Виконати FMECA досліджуваної системи:
   – визначення типів відмов і режимів роботи системи;
   – визначення наслідків відмов, критичності та їх ймовірності;
   – визначення першопричин несправностей.
   – розрахувати коефіцієнт RPN.

### Необхідні ресурси

ПК або мобільний пристрій з доступом до Інтернету

### Довідкова інформація

#### Ознайомитись з методом FMEA – Failure Mode Effect Analysis

***Стислий огляд***

Аналіз видів і наслідків відмов (FMEA – Failure Mode Effect Analysis) є методом, що використовується для ідентифікації способів відмови компонентів, систем або процесів, які можуть призвести до невиконання призначеної їх функції.

***Метод FMEA допомагає ідентифікувати:***

– всі види відмов різних частин і компонентів системи (видами відмов можуть бути приховані відмови, конструктивні відмови, виробничі відмови та ін., які призводять до порушення працездатного стану частин та/або компонентів системи);

- наслідки відмов для системи;
- механізми відмови;
- способи досягнення безвідмовної роботи та/або пом’якшення наслідків для системи.

Розширеною версією методу FMEA є FMECA, що дозволяє оцінити критичність і значущість кожного ідентифікованого виду відмови. Критичність відмови – це сукупність ознак, що характеризують наслідки відмови. Класифікація відмов з критичності проводиться відповідно до законодавчих та обов’язкових вимог, і таких, що встановлюються пріоритетами організації.

Аналіз критичності зазвичай є якісним або змішаним, але може бути кількісним при використанні показника фактичного відсотка відмов.

***Сфера застосування***

Залежно від об'єкта дослідження виділяють кілька варіантів методу: FMEA проекту або продукції, FMEA процесу, що застосовується для аналізу виробничих і складальних процесів, FMEA системи, FMEA послуги і FMEA програмного забезпечення.

Метод FMEA/FMECA може бути застосований на стадіях проектування, виробництва та експлуатації виробничої системи. Однак для підвищення надійності внесення змін на стадії проектування системи є більш ефективним. Методи FMEA і FMECA також можуть бути застосовані до процесів і процедур, наприклад, ці методи застосовують для виявлення можливості медичних помилок і дефектів у процесі технічного обслуговування. Методи ***FMEA/FMECA можуть бути використані:***

- при виборі з альтернативних варіантів проекту з високою надійністю;
- для дослідження всіх видів відмов систем і процесів та їх впливу на безвідмовність досліджуваного об'єкта;
- для ідентифікації наслідків помилок персоналу (вплив людського фактора);
- при плануванні перевірок (тестів) і технічного обслуговування технічних систем;
- для поліпшення проектів процедур і процесів;
- для отримання якісної або кількісної інформації для інших методів аналізу, таких, як аналіз дерева несправностей.

Результати методів FMEA і FMECA можуть бути використані як якісні та кількісні вхідні дані для інших методів досліджень, таких, як, наприклад, аналіз дерева несправностей [18].

***Вхідні дані***

Для виконання методів FMEA і FMECA необхідна детальна інформація про елементи системи, достатня для аналізу способів і шляхів розвитку відмови кожного елемента. Для детального застосування методу FMEA до проекту елемент системи може бути розглянутий на рівні його компонентів, у той час як для FMEA системи в цілому елементи системи можуть бути визначені на укрупненому рівні (у вигляді блоків і підсистем).

***Інформація може включати:***

- креслення і блок–схеми аналізованої системи та її компонентів або етапи процесу;
- інформацію про функціонування кожного етапу процесу або компонента системи;
- докладний опис екологічних та інших параметрів, які можуть впливати на функціонування системи;
- відомості про результати відмов;

- хронологічні дані про відмови, включаючи доступні дані про інтенсивність відмов [19].

***Процес виконання методу***

Процес FMEA включає основні етапи.

1. Визначення сфери застосування і цілей дослідження.
2. Формування робочої групи.
3. Вивчення системи/процесу, для яких застосовують метод FMECA.
4. Розподіл системи на компоненти або етапи;
5. Визначення функції кожного етапу або компонента.
6. Визначення для кожного компонента або етапу:
   - можливих відмов та їх причин;
   - механізмів, що призводять до цих видів відмови; – наслідків відмов;
   - рівень безпеки або руйнівності наслідків відмови;
   - способи виявлення відмови.
7. Ідентифікація особливостей проекту, що дозволяють компенсувати відмову.

При виконанні методу FMECA робоча група додатково класифікує кожну з ідентифікованих видів відмов відповідно до її критичності. Існує декілька способів виконання аналізу критичності відмов. Загальноприйнятий метод включає визначення:

- показника критичності виду відмови;
- рівня ризику;
- рангу пріоритетності ризику.

Модель критичності виду відмови є мірою можливості того, що досліджуваний вид відмови компонента призведе до відмови системи в цілому. Критичність відмови визначають як добуток ймовірності наслідків відмови на інтенсивність виду відмови і на час функціонування системи. Цю формулу часто застосовують до відмов обладнання в ситуації, коли кожен з цих показників може бути визначений кількісно, і види відмови мають однакові наслідки.

Рівень ризику визначають як поєднання наслідків виду відмови та ймовірності цієї відмови, він може бути використаний в ситуації, коли наслідки різних видів відмов різні, його застосовують до систем і процесів, пов’язаних із обладнанням. Рівень ризику може бути поданий у якісному, змішаному або кількісному вигляді.

Ранг пріоритетності ризику (RPN – Risk Priority Number) є змішаною мірою критичності відмови, його розраховують шляхом множення рангу значущості наслідків відмови (зазвичай від 1 до 10) на ймовірність відмови і можливість виявлення проблеми. Якщо відмову важко виявити, то їй зазвичай приділяють більше уваги і надають першочергового значення. Цей метод використовують найчастіше в процесі забезпечення якості.

З моменту ідентифікації видів відмов та механізмів їх виникнення слід визначити та впровадити коригувальні дії для найбільш істотних видів відмов. Результати виконання методу FMEA повинні бути задокументовані у вигляді звіту, який повинен містити:

- докладний опис системи, що досліджується;
- способи, використані для виконання аналізу;
- припущення, зроблені в процесі виконання аналізу;
- джерела даних;
- отримані результати, включаючи заповнені контрольні листи;
- критичність (якщо потрібно) і методи, використані для її визначення;
- рекомендації для подальших досліджень, зміни проекту або особливості, які необхідно включити до планів перевірок, випробувань та ін. Система може бути повторно оцінена в іншому циклі FMEA, після того як всі необхідні дії щодо проведення аналізу будуть завершені [18].

***Вихідні дані***

Первинними вихідними даними методу FMEA є перелік видів відмов, механізмів виникнення відмови і його наслідків для кожного компонента системи або етапу процесу (які можуть включати в себе інформацію про ймовірність відмови). До вихідних даних також належить інформація про причини та наслідки відмов для системи в цілому. Вихідні дані методу FMECA містять результати ранжирування значущості відмов на основі оцінення ймовірності відмови системи, рівня ризику виникнення цього виду відмови або комбінації рівня ризику і «можливості виявлення» виду відмови.

Метод FMECA може бути корисний для отримання кількісних вихідних даних при використанні кількісних даних про інтенсивність відмов та їх наслідки.

***Переваги та недоліки***

***Переваги методу FMEA/FMECA:***

- метод застосовують до видів відмов, пов’язаних із помилками персоналу, порушенням працездатності обладнання та роботи систем програмного забезпечення і процесів;
- метод дозволяє ідентифікувати види відмов компонентів, причини цих відмов та їх наслідки для системи і подати їх у зручній для користувача формі;
- застосування методу допомагає уникнути дорогих модифікацій обладнання при технічному обслуговуванні за рахунок ідентифікації та усунення проблем на ранніх стадіях етапу проектування;
- метод дозволяє ідентифікувати види відмов в окремій точці і встановити вимоги до резервування та систем безпеки;
- метод дає можливість отримати вхідні дані для розробки програм моніторингу, надаючи інформацію про необхідні об’єкти моніторингу та їх особливості [19].

***Недоліки методу:***

- метод FMEA/FMECA може бути використаний тільки для ідентифікації окремих відмов, а не їх поєднання;
- без адекватного контролю і спеціальної спрямованості такі дослідження можуть бути трудомісткими і дорогими;

- застосування методу FMEA/FMECA може бути трудомістким і тривалим для складних багаторівневих систем.

***Посилання на стандарти***

МЕК 60812 Методи аналізу надійності систем. Метод аналізу видів і наслідків відмов (FMEA).

***Приклад FMECA - аналіз несправності двигуна автомобіля***

Під час аналізу несправності двигуна автомобіля за допомогою FMECA ми визначаємо потенційні типи несправностей. Далі ми визначимо їх вплив. Потім визначте пріоритети цих режимів відмови для пом'якшення. Розглянемо деякі поширені види несправностей системи безпеки розумного будинку.

**компонент:** Поршень

**функція:** Рухається вгору і вниз по циліндру.

**Режим несправності:** Заїдання (застрягання через відсутність мастила).

**компонент:** Паливний інжектор

**функція:** Розпилює паливо в циліндри.

**Режим несправності:** Засмічення (перешкода, що перешкоджає потоку палива).

**компонент:** Свічка запалювання

**функція:** Запалює паливно-повітряну суміш.

**Режим несправності:** Забруднення (накопичення відкладень, що перешкоджають займанню).

**компонент:** Охолоджувальна система

**функція:** Регулює температуру двигуна.

**Режим несправності:** Витік охолоджуючої рідини (витік, що призводить до перегріву).

Нижче наведено візуальне представлення ефектів і пріоритетів цього аналізу FMECA.

| FAILURE MODE | EFFECTS | SEVERITY | PROBABILITY | DETECTABILITY | RPN |
|---|---|---|---|---|---|
| Seizure | Engine breakdown, damage | High | Low | Moderate | 24 (Moderate) |
| Clogging | Reduced engine performance | Moderate | Moderate | High | 20 (Moderate) |
| Fouling | Starting issues, misfires | Low | High | High | 15 (Low) |
| Coolant Leak | Engine overheating, damage | High | Moderate | Low | 20 (Moderate) |

Рисунок 4.1 Візуальне представлення ефектів і пріоритетів аналізу FMECA.

**Розрахунок RPN (Risk Priority Number):**

- Формула: **RPN=Критичність×Ймовірність.**

- Чим вищий **RPN,** тим більший пріоритет слід надати аналізу та усуненню цієї потенційної відмови.
- **Присвоєння рівнів критичності та ймовірності:**
- **Критичність (1-10):** оцінюється за впливом відмови на загальну безпеку системи..
- **Ймовірність (1-10):** базується на оцінці вірогідності виникнення відмови.
- **Аналіз структури та функцій системи безпеки розумного будинку.**
- **Система безпеки складається з центрального контролера, сенсорів руху, датчиків відкриття дверей/вікон, відеокамер, сигналізації, мобільного додатку та хмарного сервера.**
- **Поділ системи на компоненти для ідентифікації потенційних точок відмов.**
- **Кожен компонент системи може мати свої потенційні відмови, які впливають на функціонування всієї системи.**
- **Виконання FMECA-аналізу для оцінки ризиків та критичності відмов.**

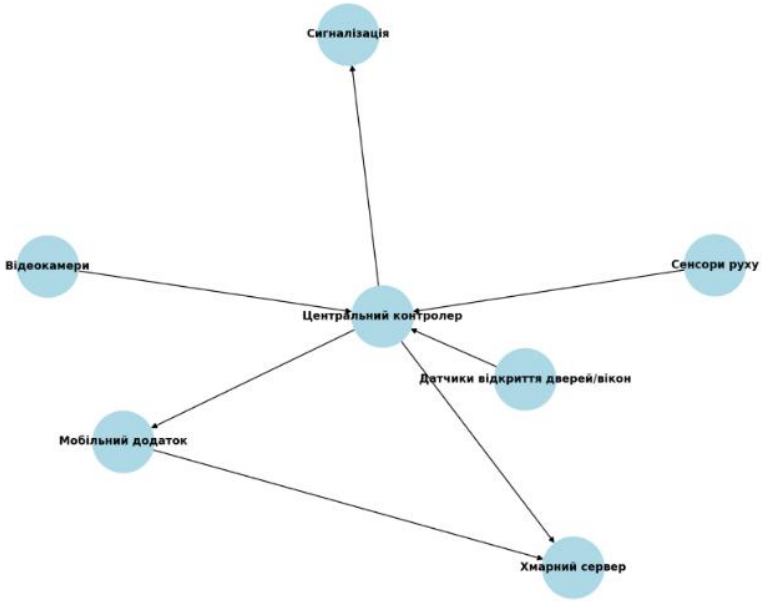



Рисунок 4.2 Функціональна схема системи безпеки розумного будинку

**Етапи створення таблиці**

**Ідентифікація основних компонентів системи:**

**Визначення типів відмов для кожного компонента:**

- **Сенсори руху:** можуть не реагувати на рух через механічний збій або проблеми з живленням.
- **Датчики відкриття дверей/вікон:** можуть не фіксувати відкриття через несправність сенсора або втрату з'єднання.
- **Відеокамери:** можуть втратити сигнал або не передавати відео через збої у мережі або обладнанні.

- **Центральний контролер:** ризикує повною відмовою обробки даних у разі збою програмного забезпечення або апаратної частини.
- **Сигналізація:** може не спрацювати через апаратні несправності або проблеми з підключенням до контролера.
- **Мобільний додаток:** можливість втрати доступу через програмні помилки або проблеми з мережею.
- **Хмарний сервер:** втрата з'єднання через мережеві збої або технічне обслуговування.

Таблиця 3.1. FMECA-аналізу

| Компонент | Тип відмови | Наслідки відмови | Критичність | Ймовірність | RPN (Ранг пріоритету ризику) |
|---|---|---|---|---|---|
| Сенсори руху | Не реагує на рух | Відсутність виявлення вторгнення | 8 | 3 | 24 |
| Датчики відкриття дверей/вікон | Не фіксує відкриття | Не виявлено вторгнення | 7 | 4 | 28 |
| Відеокамери | Не передає відео | Втрата відеоспостереження | 9 | 2 | 18 |
| Центральний контролер | Відмова обробки даних | Вся система не працює | 10 | 3 | 30 |
| Сигналізація | Не активує тривогу | Відсутність сповіщення | 9 | 2 | 18 |
| Мобільний додаток | Немає доступу до системи | Користувач не отримує сповіщення | 6 | 3 | 18 |
| Хмарний сервер | Втрата з'єднання | Відсутність доступу до даних | 8 | 4 | 32 |

**Оцінка наслідків відмов:** Наслідки варіюються від **часткових** (наприклад, відсутність сповіщення у разі несправності мобільного додатка) до **критичних** (повна відмова системи при несправності центрального контролера).

**Присвоєння рівнів критичності та ймовірності:**

- **Критичність (1-10):** оцінюється за впливом відмови на загальну безпеку системи. Наприклад, відмова центрального контролера має найвищу критичність — **10**, оскільки це "серце" системи.
- **Ймовірність (1-10):** базується на оцінці вірогідності виникнення відмови. Наприклад, мережеві збої для хмарного сервера трапляються частіше, ніж механічні несправності сенсорів, тому для сервера встановлена вища ймовірність — **4**.

**Розрахунок RPN (Risk Priority Number):**

- **Формула: RPN=Критичність×Ймовірність.**
- Чим вищий RPN, тим більший пріоритет слід надати аналізу та усуненню цієї потенційної відмови.

**Питання для самоперевірки:**

1. Що допомагає ідентифікувати Метод FMEA ?
2. У яких сферах застосовується Метод FMEA?
3. Які вхідні дані використовує Метод FMEA?
4. Які особливості процесу виконання методу FMEA?
5. Які переваги на недоліки методу FMEA?

## Рекомендована література


**1** Управління інформаційною безпекою: конспект лекцій [Електронний ресурс] : навч. посіб. для студ. спец. 125 «Кібербезпека» / КПІ ім. Ігоря Сікорського; уклад.: С. О. Носок, О. М. Фаль, В. М. Ткач. – Електронні текстові дані (1 файл: 1114 Кбайт). – Київ : КПІ ім. Ігоря Сікорського, 2021. – 258 с.

**2** Roman V. Yampolskiy. Artificial Intelligence Safety and Security. CRC Press, 2018. – 444 p.

**3** Кормич В.А. Інформаційна безпека: організаційно-правові основи: Навчальний посібник./МОН.-К.:Кондор, 2008.-283с.

**4** Бабак В.П. Теоретичні основи захисту інформації / В. П. Бабак: Підручник. – Книжкове видавництво НАУ, 2008. – 752 с.

**5** Бурячок В.Л., Гулак Г.М., Толубко В.Б. Інформаційний та кіберпростори: проблеми безпеки, методи та засоби боротьби. Магнолія 2006., К. 2021. – 450 с.

**6** В.П. Бабак, О.Г. Корченко. Інформаційна безпека та сучасні мережеві технології. – К.: НАУ, 2003. – 670 с.

**7** Юдін О.І., Корченко О.Г., Конахович Г.Ф., Захист інформації в мережах передачі даних – К.: Вид-во ТОВ "НВП"Інтерсервіс", 2009.-716с.

**8** ДСТУ ISO/IEC TR 13335-2-2003 Інформаційні технології. Настанови з керування безпекою інформаційних технологій (IT). Частина 2. Керування та планування безпеки IT (ISO/IEC TR 13335-2:1997, IDT).

**9** ДСТУ ISO/IEC TR 13335-3-2003 Інформаційні технології. Настанови з керування безпекою інформаційних технологій (IT). Частина 3. Методи керування захистом IT (ISO/IEC TR 13335-3:1998, IDT).

**10** Є.Яковенко, І. Журавель, І. Горбатий, А. Бондарєв. Інформаційна безпека. Львівська політехніка. Львів, 2019. – 580 с.

**11** Задирака В.К., Олексюк О.С. Методи захисту фінансової інформації: Навчальний посібник. - Тернопіль: “Збруч”, 2000. - 460с.

**12** Закон України «Про захист інформації в автоматизованих системах»

**13** Заплотинський Б.А. Основи інформаційної безпеки. Конспект лекцій. –КІІВіП НУ “ОЮА”, кафедра інформаційно-аналітичної та інноваційної діяльності, 2017. – 128 с

**14** Хенлі Ернест Джон, Кумамото Хиромицу Надійнісне проектування технічних систем і оцінка ризику./ пер. з англ. О.Ю.Зареніна, В.Ф. Хмеля; під ред. Ю.Г.Зареніна.-К.: Вища школа, 1987.-544 с.

**15** Комплексна безпека інформаційних мережевих систем: навчальний посібник / Укладачі : Микитишин А.Г., Митник М.М., Стухляк П.Д. – Тернопіль : Вид-во ТНТУ імені Івана Пулюя, 2016. – 256 с.

**16** ISO/IEC 27035. Information technology. Security techniques. Information security incedent management. – 2011. – 78 p. 4 17.

**17** 5. Swanson M. NIST Special Publication 800-34 Rev. 1 Contingency Planning Guide for Federal Information Systems / M. Swanson, P. Bowen, A. W. Phillips, D. Gallup, D. Lynes. – 2010. – 149 p.

**18** Нашинець-Наумова А.Ю. Інформаційна безпека: питання правового регулювання. – К.: ВД “Гельветика”, 2017. – 168 с

**19** Baseline Security Recommendations for IoT in the context of Critical Information Infrastructures. – The European Union Agency for Network and Information Security, 2017

**20** Hutchins E., Cloppert M., Amin R. Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains. – Lockheed Martin Corporation, 2017.

**21** Орлов П.І.. Інформація та інформатизація. – Харків: НУВС. - 2003.- 723с.

**22** Остроухов В.В., Присяжнюк М.М., Фармагей О.І., Чеховська М.М. Інформаційна безпека. Підручник. Ліра-К. – К.-2021. – 412 с.

**23** Савченко Ю.Г., Хлобистова О.А., Гладка М.В. Технології захисту інформації: навчальний посібник для студентів напряму підготовки 6.050101 «Комп'ютерні науки» заочної та скороченої форми навчання. – К.: НУХТ, 2013. – 84 с.

**24** Широчин В. П., Широчин С. В., Мухін В. Є. Основи безпеки комп`ютерних систем. К.: «Корнійчук». 2009 С.285.

## ДОДАТОК А. Приклад тем для дослідження

Дослідження структури системи управління кібернетичною безпекою…

| | | | |
|---|---|---|---|
| **1.** | Поліклініки | **2.** | Друкарні |
| **3.** | Рекламної агенції | **4.** | Перукарні |
| **5.** | Пенсійного фонду | **6.** | Податкової адміністрації |
| **7.** | Аптеки | **8.** | Музичного відділу радіостанції |
| **9.** | Архіву | **10.** | Газети |
| **11.** | Абонементу бібліотеки | **12.** | Автоінспекції |
| **13.** | АЗС | **14.** | Автостоянки |
| **15.** | Санаторію | **16.** | АТС |
| **17.** | Будівельної організації | **18.** | Банківської установи |
| **19.** | Букмекерської контори | **20.** | Бухгалтерії |
| **21.** | Комітету профспілок | **22.** | Відділу РАГСу |
| **23.** | Гуртожитку | **24.** | Військкомату |
| **25.** | Деканату ЗВО | **26.** | Гаражного кооперативу |
| **27.** | Диспетчерської авіаперевезень | **28.** | Готелю |
| **29.** | Диспетчерської вантажних перевезень | **30.** | Агентства з торгівлі цінними паперами |
| **31.** | Диспетчерської кур’єрської пошти | **32.** | Диспетчерської автовокзалу |
| **33.** | Казначейства | **34.** | Інформаційно-аналітичного відділу |
| **35.** | Кадрової агенції | **36.** | Служби знайомств |
| **37.** | Служби зайнятості | **38.** | Енергорозподільчої компанії |
| **39.** | Інтернет-салону | **40.** | Станції технічного обслуговування |
| **41.** | Дошкільного закладу | **42.** | Диспетчерської радіотаксі |
| **43.** | Диспетчерської поштового відділення | **44.** | Заводу з виробництва продовольчої продукції |
| **45.** | Заводу з виробництва та комплектування автомобілів | **46.** | Диспетчерської залізничних перевезень |
| **47.** | Центру сертифікатних аукціонів | **48.** | Стоматологічної поліклініки |
| **49.** | Кемпінгу | **50.** | Кінотеатру |
| **51.** | Митниці | **52.** | Контрольно-ревізійного управління |
| **53.** | Лікарні | **54.** | Метрополітену |

| | | | |
|---|---|---|---|
| **55.** | Управління захисту прав споживачів | **56.** | Заводу з виробництва промислової продукції |
| **57.** | Музею | **58.** | Нотаріальної контори |
| **59.** | Обмінного пункту | **60.** | Ресторану |
| **61.** | Туристичної фірми | **62.** | Управління екології |
| **63.** | Страхової компанії | **64.** | Фотоцентру |
| **65.** | Цукрового заводу | **66.** | Хімчистки |
| **67.** | Школи | **68.** | Центру статистики |
| **69.** | Кав’ярні | **70.** | Доставки їжі |